

Lab 01 — Enumeración y explotación de un servicio vulnerable

CyberLabs · Vivianne García · Universidad Tecnológica de Panamá

Ficha técnica

Categoría	Pentest
Tema	Reconocimiento y explotación de un servicio de red vulnerable
Nivel	Medio
Entorno	Kali Linux (atacante) + máquina víctima vulnerable, en VM sobre Mac
Estado	Borrador de enunciado — sin resolver

Escenario

Trabajas como practicante en el equipo de seguridad ofensiva de una empresa ficticia. Te asignan una única máquina dentro de un rango de laboratorio interno para hacer una evaluación de seguridad básica: identificar qué servicios expone, detectar si alguno tiene una vulnerabilidad conocida, y — si es posible — obtener acceso a la máquina aprovechando esa debilidad. El objetivo del ejercicio no es memorizar un comando, sino practicar el flujo completo: reconocimiento → identificación de la vulnerabilidad → investigación → explotación → documentación.

Objetivo

Obtener acceso (shell) a la máquina víctima aprovechando un servicio de red mal configurado o con una vulnerabilidad pública conocida, y documentar todo el proceso en tu writeup.

Alcance y reglas

- El único objetivo autorizado es la IP de tu propia máquina víctima, dentro de tu red interna/host-only de laboratorio. Nunca apuntes estas técnicas a sistemas que no te pertenecen o no tienes autorización explícita para probar.
- No se permite tráfico hacia redes externas o internet durante la explotación (aislar la red virtual).
- El ejercicio es no destructivo: evita borrar archivos, crear usuarios persistentes o modificar la configuración del sistema víctima más allá de lo necesario para demostrar el acceso.
- Toma una snapshot de ambas VMs antes de empezar, para poder revertir si algo sale mal.

Preparación del entorno

Ya cuentas con tu VM de Kali Linux. Para este lab necesitas además una segunda VM que actúe como víctima intencionalmente vulnerable:

- Descarga la imagen de **Metasploitable2** (VM oficial de prácticas, ampliamente usada en formación de pentesting; búscala por ese nombre exacto en una fuente oficial/reconocida).
- Impórtala en tu hipervisor (VirtualBox, UTM, VMware, etc., según lo que uses en tu Mac).
- Configura una red tipo *host-only* o *internal network* compartida entre Kali y Metasploitable2, para que se vean entre sí sin exponer la víctima a tu red real ni a internet.
- Enciende ambas VMs y confirma conectividad básica entre ellas (por ejemplo, con un ping desde Kali hacia la IP de la víctima).
- Antes de tocar nada, toma una snapshot de la VM víctima en su estado inicial.

Pistas progresivas

Úsalas en orden, solo cuando te trabes. Cada una da un poco más de dirección que la anterior.

Pista 1 — General

Empieza con un escaneo de puertos completo (todos los puertos, no solo los más comunes) y detección de versión de servicio. Anota todos los puertos abiertos antes de enfocarte en uno solo.

Pista 2 — Un poco más específica

De los servicios que encuentraste, hay uno cuya versión reportada es inusualmente antigua. Busca en una base de datos de vulnerabilidades (CVE, Exploit-DB) el nombre y número de versión exactos de ese servicio.

Pista 3 — Más específica

El servicio en cuestión corre sobre el puerto de FTP. La versión específica que vas a encontrar tiene una vulnerabilidad muy conocida en la comunidad de pentesting, ligada a una 'puerta trasera' (backdoor) que se activa de una forma particular al autenticarse. Investiga el CVE asociado a esa versión.

Pista 4 — Casi al grano

Metasploit trae un módulo listo para esta vulnerabilidad (puedes buscarlo dentro de msfconsole filtrando por el nombre del servicio). También puedes intentarlo de forma manual, entendiendo qué envía exactamente ese exploit al servidor para activar la puerta trasera — eso es justo lo que deberías explicar con tus propias palabras en el writeup.

Entregable

Tu entregable es el archivo **writeup.md** dentro de esta misma carpeta del lab, completado con la plantilla del proyecto (*templates/writeup-template.md*): reconocimiento, metodología, hallazgos, evidencia, solución/explotación, remediación, lecciones aprendidas, herramientas y referencias. Cuando lo termines, haz commit del lab en el repositorio.

Este enunciado no incluye la solución ni el comando/payload final. Resuélvelo con las pistas de arriba y, si te trabas, pide ayuda en modo tutor (una pista puntual, revisión de un comando, o explicación de un concepto) en vez de la respuesta directa.